

PNK Suguan — Super Admin Guide

PNK Suguan 2.1.0 — release documentation (source: SUPER-ADMIN-GUIDE.md)

Administrator reference for the SUPER_ADMIN role.

This guide describes what the SUPER_ADMIN account can actually do in the PNK Suguan System, how to use the exceptional lock-breaking procedures safely, and the security practices that keep them exceptional. It contains **no credentials of any kind** — every value described here is a **procedure**, never a password, secret, or key.

1. What the SUPER_ADMIN role is

SUPER_ADMIN is the system's highest role, and it exists for **one purpose above all others**: keeping a **published** schedule correctable in a genuine emergency, without weakening the normal lifecycle (DRAFT -> FINALIZED -> PUBLISHED) for everyone else.

It is:

- **not a normal administrative role** — it is provisioned deliberately, by an operator, outside the application;
- **never selectable in the User Management form** (Create/Edit User offer only Administrator, Scheduler/Encoder and Viewer). No code path in the application grants SUPER_ADMIN;
- **audited like any other account** — provisioning, unlocks, corrections, restores, and account changes all leave audit rows;
- **protected as an account class**: a SUPER_ADMIN user row can only be modified by another SUPER_ADMIN. A normal Administrator cannot deactivate, re-role, or reset a SUPER_ADMIN account.

Everything else SUPER_ADMIN can do, it can do because it holds the complete Administrator permission set. The exceptional abilities are **additive**, not a replacement for normal administration.

2. The three credentials — do not mix them up

Credential	What it is	Where it lives	How it is rotated
SUPER_ADMIN account	Admin user account holding the SUPER_ADMIN role. Signs in exactly like any other user.	The users table (argon2id hash)	Sign in and change the password (this revokes every session for the account), or use the operator recovery script (section 7)
Unlock secret	A server-side secret entered in the Emergency Correction dialog. It opens a temporary correction window on one PUBLISHED week. It is not an account password and cannot sign anyone in.	The machine's secret store (the data folder's .env for packaged installs)	Replace the value, then restart the application
Unlock grant	The temporary window created by one successful unlock.	Runtime state derived from the audit trail; expires automatically	Nothing to rotate — it simply expires

The unlock secret is compared server-side with a timing-safe comparison, is **never logged, never echoed back to the browser and never returned by any API**, and a wrong secret produces the **same** generic error as a wrong role or a wrong week state — so the dialog cannot be used to discover anything. If the secret is not configured, the PUBLISHED unlock fails closed (it refuses to open).

3. Signing in to the SUPER_ADMIN account

1. Open the application (the PNK Suguan shortcut, or the loopback address shown by the launcher).
2. Sign in with the SUPER_ADMIN account's e-mail and password.
3. If the account was **just provisioned or recovered**, the system forces a password change before

any other page can be reached. Choose a new password and enter it twice.

1. Expect to be signed out and asked to sign in again after a password change — this is intentional.

Changing a password **revokes every active session** for that account.

Session behaviour: sessions last 12 hours, are re-verified against the database on every request, end on sign-out, end immediately if the account is deactivated, and are all revoked when the account's password changes.

Password policy (enforced server-side): at least 10 characters including an uppercase letter, a lowercase letter, a digit and a symbol.

Store the SUPER_ADMIN password in the organisation's password manager — never in a note file, never in the data folder, never in the program folder.

4. Capabilities at a glance

Area	What SUPER_ADMIN can do	Notes
Users	Create users, edit names, assign/remove roles (Administrator, Scheduler/Encoder, Viewer), deactivate/reactivate, reset passwords	Only a SUPER_ADMIN may act on another SUPER_ADMIN's account
Teachers / Dako	Full create, edit and deactivate/disable rights, including Current Destination and Duty changes	Every destination change is transactional and preserves history
Weekly schedule	Generate, edit, clear, replace, finalize, publish; revise a FINALIZED week; break the PUBLISHED lock in an emergency (section 5)	Hard rules (e.g. a Filipino teacher on an English dako) are never overridable by any role
Weekly availability	Encode availability; open a correction window on a PUBLISHED week (section 6)	The week's published status never changes
Magtuturo	View and manage classroom teaching assignments	
Reports	Every read-only report, including the Teacher Masterlist and its PDF exports	Read-only; reports never modify scheduling data
Backup / Restore	Create backups and restore the database	Restore is restricted to Administrator and SUPER_ADMIN
Audit	Read the complete administrative action history	
Notifications	Read and author notifications	

5. Emergency correction of a PUBLISHED week

Use this only when a published schedule is genuinely wrong and the correction cannot wait for the normal cycle.

The week stays PUBLISHED throughout — you are opening a temporary, audited work window, not un-publishing the schedule.

1. Open **Weekly Schedule** and select the affected year and ISO week.

2. Choose the **Emergency Correction** action (this entry point is visible only to a SUPER_ADMIN).
3. Enter the **unlock secret** and a **reason**. Both are required; the reason is stored in the audit

trail with the grant.

1. Confirm. A correction window opens for that week only, for **30 minutes**, held by you.
2. Make the corrections. Each individual change is validated by the normal rules and audited.
3. The window **expires automatically** after 30 minutes; you may also end it deliberately when you

are finished. Ending it early is the safer habit.

If the secret is wrong, unset, or the week is not in a correctable state, the dialog fails with a generic message and no window opens. Repeated failures reveal nothing about the secret.

6. Correcting availability on a PUBLISHED week

The same protection applies to Weekly Availability: a PUBLISHED week's availability is frozen, and only a SUPER_ADMIN can temporarily reopen it.

1. Open **Availability** for the affected year and ISO week.
2. Start the correction (SUPER_ADMIN-only). A reason is required and is audited.
3. Encode the corrected availability within the **30-minute** window.
4. The window expires on its own, or you may end it when finished.

Availability corrections leave the week's PUBLISHED state untouched and never rewrite already-generated assignments — regeneration remains an explicit, separate action.

7. Provisioning, recovery and rotation

These are **operator actions on the machine hosting the application** (they ship with the source, not with the installer). They print one-time passwords to the terminal exactly once.

- **Provision (or re-provision) the SUPER_ADMIN account**

```
`` node node_modules/tsx/dist/cli.mjs scripts/provision-super-admin.ts --email <address> ``
```

A new address creates the account with a one-time random password and forces a change at first sign-in. An existing address rotates the one-time password, re-forces the change, ensures the role grant, and revokes that account's sessions. Safe to re-run. An INACTIVE account is refused — reactivate it in User Management first.

- **Recover a lost SUPER_ADMIN password**

```
`` node node_modules/tsx/dist/cli.mjs scripts/reset-super-admin.ts --email <address> ``
```

Prints a one-time password, forces a change at next sign-in, revokes all sessions, and audits the reset. It refuses any account that does not hold SUPER_ADMIN, and it never accepts a password as an argument — so no operator ever chooses (or leaves in shell history) another person's final password.

- **Rotate the unlock secret** — replace the value in the machine's secret store and restart the

application. Existing grants are unaffected; new unlocks use the new value. Never copy the secret store anywhere, and never place it in the program folder or a distribution package.

- **Rotate a SUPER_ADMIN account password** — sign in and change it, or run the recovery script.

8. Backup and restore

- **Create a backup** — the backup is written with PostgreSQL's custom archive format and validated by

reading its table of contents, so a backup is only reported as created when it is genuinely readable.

- **Restore** — restoring replaces this machine's database with the chosen backup. It is restricted to

Administrator and SUPER_ADMIN, requires the application's normal confirmation, and is audited. Everything in the current database that is not in the backup is lost, so: 1. create a fresh backup immediately before any restore; 2. confirm the selected file is the intended one (the file's timestamp and inspection result are shown); 3. do the restore at a moment when nobody is encoding schedules; 4. verify the result by signing in and checking the current week before continuing work.

Backups contain live operational data (and, depending on what you store, personal data). Store them on an encrypted volume with the same care as the database itself.

9. Security practices for this account

- Use the SUPER_ADMIN account **only** for the exceptional operations it exists for. Do everyday work with your own Administrator or Scheduler/Encoder account.
- Keep the password and the unlock secret in a password manager, never in shared notes or chat.
- Never share the unlock secret with a scheduler or encoder — the reason a PUBLISHED correction is gated is that it is exceptional, and the audit trail names the holder of every grant.
- Rotate the unlock secret whenever someone who knew it leaves the organisation, and rotate the account password at the same time.
- Review the **Audit Log** after every emergency unlock or restore, and confirm each row matches what you intended to do.
- Deactivate the SUPER_ADMIN account's sessions by changing its password if you suspect it was used without authorisation; then investigate the audit trail.
- Never copy the data folder's `.env` — it holds this machine's live secrets.

10. What this account deliberately cannot do

- It cannot be granted through the application's User Management screens.
- It cannot override the absolute business rules: a Filipino teacher can never be placed on an English dako, and a disabled dako can never receive an assignment — no role, and no reason, changes that.
- It cannot change a PUBLISHED week's status by using the emergency unlock: the unlock opens a work window and leaves the week PUBLISHED.
- It cannot make a correction without a reason and without leaving an audit row.
- It cannot recover its own password through the ordinary Forgot-Password flow without another SUPER_ADMIN acting on its behalf; the operator scripts in section 7 are the sanctioned path.

PNK Suguan System — administrator reference. Procedures only; no credentials are described, stored, or reproduced in this document.